

Mind the Hook: Source-Level Auditing of Privacy Defenses in Retrieval-Augmented Generation

Yanhang Li
Northeastern University
Boston, MA, USA
li.yanha@northeastern.edu

Zhichao Fan
University of Illinois Urbana-Champaign
Urbana, IL, USA
zhichao8@illinois.edu

Zexin Zhuang
Southern Methodist University
Dallas, TX, USA
zexinz@smu.edu

Abstract—Black-box privacy scores for retrieval-augmented generation (RAG) are difficult to interpret unless the audited defense’s active pipeline hook is known. We propose an *active-path audit*: inventory source-level hooks over retrieval, retrieved content, and generation; map each metric to the leakage channel it observes; and validate generated-text effects with exact-match canaries. In our benchmark reimplementations, the DP-style defenses modify retrieval scores only: their generation hooks are TODO-flagged stubs that return responses unchanged. This active path explains why they affect membership-inference behavior but track NO-DEFENSE on generated-text named-entity leakage, measured by NEL_{strict} . By contrast, the end-to-end LPRAG path is canary-validated on the email channel, recovering 53/150 canaries under NO-DEFENSE and 0/150 under LPRAG. These findings concern our reimplementations on our stack, not released defenses or defense families; the contribution is a methodology and case study, not a universal ranking.

Index Terms—retrieval-augmented generation, privacy audit, source-level audit, differential privacy, membership inference, named-entity leakage, canary

I. INTRODUCTION

A RAG privacy defense can be present in a codebase yet inactive on the leakage channel being measured. If the implementation modifies only retrieval, a privacy metric scored on the generated text cannot see whether the defense works; if it modifies only the response, a metric scored on the retrieval/index path cannot see it either. Most current evaluations of RAG privacy defenses report only black-box leakage numbers, leaving this kind of channel–implementation mismatch invisible.

We make this concrete with a *source-level active-path audit* (§III): for each defense, inspect which pipeline hook (retrieval scoring, retrieved-content rewriting, generation, output post-processing) the implementation actually modifies; map each privacy metric to the channel it observes; and interpret metric movement only when the defense can act on that channel. End-to-end effects on the generated-text channel are then validated with exact-match canaries, which are not scored by the heuristic classifier.

We apply this audit to one fixed open-source RAG stack (Phi-3-mini-4k-instruct [1] at 4-bit NF4, FAISS [2] over all-MiniLM-L6-v2 sentence-transformer embeddings [3], top- $k=5$, greedy decoding) with six attack families (four extraction baselines, the agent attacker of [4], and a black-box membership-inference attack inspired by [5]), six defense

implementations (a no-defense baseline, three DP-style implementations we wrote—DP-R, CA-DP, PRIVATE-RAG—a regex masker PAD, and an entity-substitution implementation LPRAG inspired by [6]), and three controlled corpora, arranged as a $6 \times 6 \times 3 \times 2 \times 2 = 432$ -cell grid (§IV; one run per cell, so all reported confidence intervals are within-instantiation only). Three findings emerge that would be hidden by a black-box-only evaluation:

- The three DP-style defense implementations in our benchmark act *only* on retrieval scores: their generation hooks are TODO-flagged pass-throughs (Table I). This explains why they reduce MI AUC on Synthetic-Corp from 70.5 to 41.5–59.3 while tracking the undefended baseline on NEL_{strict} , which is scored on generated text.
- Regex masking (PAD) removes email-format strings on Synthetic-Email but does not reduce person-name leakage in our setup.
- Entity substitution (LPRAG) reduces the EMAIL_REAL sub-class of NEL_{strict} by 95.6%; an out-of-vocabulary email canary (3 seeds, 50 trials each) recovers 53/150 emails under NO-DEFENSE and 0/150 under LPRAG (Fisher $p < 10^{-14}$), independently validating the end-to-end email effect. The PERSON_NAME sub-class is structurally entangled with LPRAG’s substitution vocabulary and is exploratory.

These findings are a case study; the primary contribution is the audit methodology. Without an active-path check, a black-box evaluation would have read the DP-style implementations as “MI-reducing privacy defenses,” which is misleading: the same implementations do not perturb generated text. The silent-stub finding is not a claim that the cited source defense papers contain stubs; it is that a benchmark wrapper can silently evaluate an implementation whose active path does not overlap the metric it reports. The methodology is general; the numeric findings are specific to this single open-source stack.

Contributions. (1) **Active-path audit protocol.** A three-step procedure: hook inventory, metric-to-channel map, and canary validation of generated-text effects (§III). (2) **Case study and silent-stub failure mode.** On a 432-cell grid, the protocol catches a silent-stub failure mode in three DP-style implementations that a black-box benchmark would miss; Table I documents the active hooks. (3) **Canary triangulation.** A targeted out-of-vocabulary email canary (3×50 trials) yields

exact-match evidence (53/150 vs. 0/150) for the one defense whose generation hook is end-to-end, and explicitly does not certify the person-name sub-class, which remains scorer-entangled. We do *not* claim a ranking of defense families or generalization beyond the audited stack.

II. RELATED WORK

Attacks on RAG and LM privacy. Zeng et al. [7] document RAG leakage under adversarial prompting; Jiang et al. [4] operationalize it with an agent-based attacker; Carlini et al. [8] extract training data from language models. We use Shokri et al. [5]’s black-box membership-inference framing, contextualised by the auditing perspective of Carlini et al. [9], and the canary methodology of [10] to validate generated-text effects independently of a heuristic scorer.

Privacy defenses for RAG. Koga et al. [11] study differentially private RAG (private-voting/partition mechanisms); He et al. [6] propose LPRAG, *local-DP* entity perturbation. Our PRIVATE-RAG is a DP-on-scores filter inspired by the former, and our LPRAG a deterministic entity-substitution simplification of the latter (without its local-DP); DP-R and CA-DP are simpler DP baselines we wrote. We audit our own implementations, not the source papers.

Algorithmic auditing and ML measurement. Source-level audits of ML systems—inspecting code and configurations rather than only black-box behavior—are an established algorithmic-auditing artefact in the sense of Raji et al. [12]. A growing line of benchmark-reliability audits makes related measurement concerns explicit—canary-based memorization auditing after unlearning [13], configuration-conditional rank instability on alignment benchmarks [14], paired sample-size budgeting for quantization benchmarks [15], and economic-validity auditing of tabular foundation models [16]. We adapt that posture to RAG privacy: an active-path check is a small, mechanical audit that catches silent-stub failure modes a single-metric benchmark would miss.

Position. We are not proposing a new attack, defense, or metric. The contribution is the methodology—hook inventory, metric-to-channel map, canary validation—and a case study on one fixed open-source RAG stack.

III. ACTIVE-PATH AUDIT METHODOLOGY

Most RAG-privacy evaluations report a leakage number per (defense, attack, corpus) cell and rank defenses by that number. The number is only as meaningful as the assumption that the defense’s implementation actually intervenes on the channel the metric reads. We make that assumption checkable with three steps.

1) **Source-level hook inventory.** For each defense module, inspect the implementation and classify which pipeline hook(s) it modifies: **retrieval scoring** (noise on similarity scores or top- k truncation), **retrieved-content rewriting, generation** (token-level noise, paraphrasing, or post-generation masking), or **none**. A hook whose body is `TODO`-flagged or returns its input unchanged is recorded as *inactive*, yielding a hook–status table (Table I).

2) **Metric-to-channel map.** For each metric, identify the channel it observes. NEL_{strict} (§V) is computed on *generated text* and moves only if a defense modifies the response; a black-box membership-inference AUC is designed to move when the *retrieval/index* path changes, though as a black-box score it can also respond to output-surface nuisance (length, masking, flattening), so we read it as channel-location evidence rather than a calibrated membership-privacy estimate. A metric is interpretable on a defense only if its active hooks overlap the metric’s channel; otherwise a shift is nuisance or a different mechanism.

3) **Canary validation.** A heuristic generated-text scorer can be entangled with a defense’s placeholder vocabulary, inflating apparent protection. We validate generated-text effects with an out-of-vocabulary canary (§VI-A): inject unique strings outside any defense’s substitution dictionary, exact-match score the response, and report recovery. The canary is not scored by the heuristic classifier—the score path is bypassed—so it cannot be inflated by scorer-vocabulary entanglement.

Audit applied to our benchmark implementations. We applied this protocol to the six defense implementations in our benchmark (Table I). Only three of the five non-NO-DEFENSE modules apply no explicit generation-stage transformation globally: the three DP-style modules (DP-R, CA-DP, PRIVATE-RAG) return the response via a `# TODO`-flagged pass-through (DP-R’s source literally reads “For now, return unmodified response (placeholder)”, with analogous paths in CA-DP and PRIVATE-RAG). PAD is pattern-limited—its generation hook fires only when its email-format regex matches—and only LPRAG performs end-to-end entity perturbation. Every result in §VI therefore audits *the specific implementations we wrote*; upstream authors of cited defense papers bear no responsibility for the `TODO` stubs our implementations contain. The point is not that any source paper ships stubs, but that a benchmark wrapper can silently evaluate an implementation whose active path does not overlap the metric it reports—which is exactly what an active-path check is meant to catch. The channel split is what reconciles the “DP reduces MI but not NEL_{strict} ” pattern as a property of the audited stubs rather than of DP on RAG retrieval in general: MI’s black-box score is retrieval-sensitive (it shifts when DP noise on retrieval changes which documents surface), whereas NEL_{strict} counts named entities in the generated text, which carries no explicit generation-stage perturbation when the generation hook is a stub (and which we observe does not move appreciably; §VI-B).

IV. ARTIFACT UNDER AUDIT

We instantiate the audit on a fixed open-source-component RAG stack (Figure 1) whose entire cell grid shares one language model, one retriever, one embedder, one top- k , and one decoding policy. Holding the stack fixed lets us compare implementations on equal terms; the cost is that we do not claim cross-stack generalization. The benchmark is a *case*

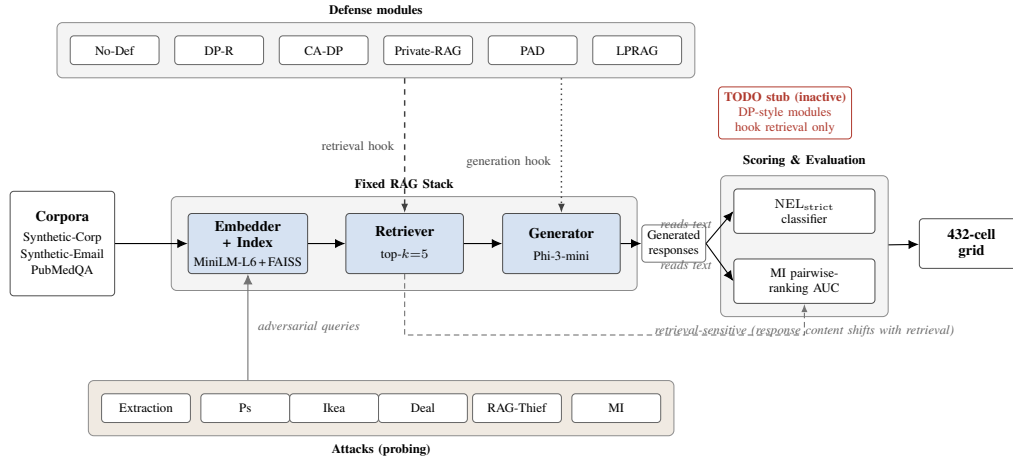


Fig. 1. Audited RAG stack and the channel split. Defenses hook the retrieval and/or generation paths (dashed = retrieval, dotted = generation; active hooks per implementation in Table I); NEL_{strict} counts named entities in the generated text, while MI is a black-box score read on the same responses but *retrieval-sensitive* (dashed bus); it shifts when retrieval perturbations change which documents surface, so each metric moves mainly when its channel’s hook fires. The attacker reads responses, not internal retrieval scores. Hook status and the 432-cell grid are detailed in §IV.

TABLE I

DEFENSE HOOK STATUS. *Stub* = A TODO PASS-THROUGH IN `APPLY_DEFENSE_GENERATION`, I.E. THE GENERATION HOOK IS INACTIVE (NO EXPLICIT OUTPUT TRANSFORMATION; ANY CHANGE IS INDIRECT, VIA ALTERED RETRIEVAL CONTEXT). DP-R, CA-DP, PRIVATE-RAG STUBS ARE IN OUR REIMPLEMENTATIONS, NOT UPSTREAM RELEASES. THE *retrieval-side* COLUMN COVERS BOTH SCORE NOISE AND RETRIEVED-CONTENT REWRITING; IT IS DISTINCT FROM THE GENERATED-TEXT PATH READ BY NEL_{strict} .

Defense	retrieval-side hook	generation hook	status
NO-DEFENSE	–	–	baseline
DP-R	DP on scores	<i>stub</i>	retr.-only
CA-DP	DP (per-turn)	<i>stub</i>	retr.-only
PRIVATE-RAG	DP on scores	<i>stub</i>	retr.-only
PAD	–	regex (on match)	pattern-lim.
LPRAG	entity sub.	entity sub.	end-to-end

study for the audit method, not a universal ranking of defense families.

A. Stack, attacks, defense implementations

The language model is Phi-3-mini-4k-instruct [1] at 4-bit NF4 quantization; retrieval uses FAISS [2] over `all-MiniLM-L6-v2` sentence-transformer embeddings [3]; top- k is fixed at 5 and generation is greedy. The raw driver produced 432 successful result JSONs (one per (attack, defense, corpus, mode, ε) cell), plus one preserved ERROR stub from a transient arithmetic-overflow on a single LPRAG cell, recovered on rerun; §VI aggregates the 432 successful cells. The attack panel has six families: four extraction baselines (PS, PM, IKEA, DEAL), a reproduction of the agent attacker of [4] (RAG-THIEF), and a black-box membership-inference attack (MI; 10 member + 100 non-member docs per corpus, black-box access to the RAG API, no shadow training, per-corpus pairwise-ranking AUC) inspired by [5] and contextualised by the auditing perspective of [9]. The defense panel has six implementations, all in our benchmark source tree: NO-DEFENSE; DP-R

(our implementation adding Laplace noise to retrieval scores, $\varepsilon \in \{1, 5\}$); CA-DP (our implementation of composition-aware DP budget across multi-turn dialogue); PRIVATE-RAG (a DP-on-scores filter inspired by, not reproducing, the DP-RAG of [11]); PAD (our regex masker for email and identifier patterns); and LPRAG (a deterministic entity-substitution simplification of the LPRAG of [6] without its local-DP perturbation—fixed names {Alice,...}, placeholder domains {example.com,...}). Results in §VI are therefore findings about *these benchmark implementations* on this stack, not about upstream releases of the cited papers. ε is inert for the three non-DP defenses; under greedy decoding and a fixed seed those $\varepsilon = 1$ and $\varepsilon = 5$ runs are *deterministic near-duplicates* rather than independent replicates, and bootstraps that pool them collapse duplicates before resampling (§V).

Threat model (compact summary). All five extraction attacks issue a fixed, bounded per-run query budget and score the generated response for named-entity leakage; MI also runs black-box against the RAG API and scores the response, but with a retrieval-sensitive membership heuristic (§V) rather than the NEL_{strict} entity count.

B. Corpora

Three corpora of 50 documents each, treated as *controlled stimuli* varying in entity density and domain, not real-deployment surrogates:

- **Synthetic-Corp:** programmatic business corpus with template-generated named entities; baseline for leakage behavior.
- **Synthetic-Email:** 50 email-formatted documents whose generator embeds Enron-era executive surnames (skilling, fastow,...) into otherwise synthetic text; used for canary validation (§VI-A).
- **PubMedQA** [17]: 1,000 real abstracts, first 50 indexed as the retrieval KB; a realistic QA workload for probing

whether DP hooks propagate into generated text.

Synthetic-Email provenance. Synthetic-Email is synthetic, produced by a Hugging Face fallback (a non-existent dataset ID, then an absent local directory, then synthetic generation, as reconstructed from run logs). It is **not** real Enron email, and we make no claim of real corporate-email or real-PII extraction from this corpus.

V. THE NEL_{STRICT} METRIC

Prior RAG privacy papers report an *extraction rate*: the fraction of target secrets recovered. That is unambiguous with known targets and exact-match scoring, but not when “a named entity” is the goal—a scorer must decide whether Jeffrey Skilling, Quantum Financial, Primary Care, and user_9266@demo.io each count. The wrong classifier yields two failure modes: **Type A (false protection)**, where a placeholder-substituting defense looks protective only because the scorer excludes its own placeholder vocabulary; and **Type B (false leakage)**, where counting organizational/topical phrases (Enron Corporation, Social Security) inflates apparent leakage under NO-DEFENSE.

Two-tier heuristic NEL. We release a ~ 50 -line rule-based regex+lexicon classifier (no second LM, whose behavior would become part of the measurement) that buckets each extracted item into one of eleven types. NEL_{strict} counts only EMAIL_REAL and PERSON_NAME and is the headline metric; it excludes PERSON_NAME_AMBIGUOUS and ORG_TITLE ($\sim 48\%$ of items), so it undercounts leakage. NEL_{strict} is a *heuristic score with limited validation*: audited at 20/20 on an informal 10-per-class positive spot-check (Clopper–Pearson one-sided 95% lower bound on 10/10 ≈ 0.74), not a stratified precision estimate and not a recall audit, hence a lower bound under a stronger attacker. Only the email sub-class has external (non-classifier) validation here, via the OOV canary (§VI-A); other cross-defense NEL_{strict} comparisons are measurements of the heuristic, not validated leakage estimates.

Aggregation and uncertainty. Each raw cell is one run; the resampling unit is the run, and for each pool we bootstrap 2,000 times and report the 95% interval. Because each cell is a single seed, every interval is **within-instantiation only**—variance across runs, not over corpus realizations or attack-query samples—and is not a population-level interval; we use overlap descriptively, never as a significance test. The driver emits $\varepsilon \in \{1, 5\}$ runs per (attack, defense, corpus, mode); these are independent for the DP defenses but *deterministic near-duplicates* for NO-DEFENSE, PAD, and LPRAG (no active DP call-site, greedy decoding, fixed seed). All reported estimates use the **deduplicated** pool ($n=30$ per non-DP defense, $n=60$ per DP defense); deduplication shifts no headline NEL_{strict} mean by more than 0.1 entities/run and flips no comparison.

MI as a separate metric. MI success is the attacker’s pairwise-ranking AUC ($\times 100$: 50 chance, 100 perfect, < 50 a score reversal), over $10 \times 100 = 1000$ (member, non-member) document-score pairs per corpus. *Each document’s score is a black-box heuristic read on the RAG’s generated responses to*

membership-probing queries (response length, target-keyword hits, presence of numbers/emails/named entities); the attacker never reads internal retrieval scores. The score is thus retrieval-*sensitive*—DP noise changes which documents surface in the response—but, being a black-box output heuristic, also responds to output-surface nuisance, which is why we read MI as channel-*location* evidence, not a calibrated membership-privacy estimate (§VII). We do *not* fold MI into NEL_{strict}: the two have different units, budgets, and responses to defenses.

VI. END-TO-END VALIDATION

All numbers use the deduplicated primary estimator (§V). Table II is the audit dashboard; we then drill into the load-bearing cells in evidentiary order: the canary (§VI-A), the MI-vs-NEL_{strict} channel split for the retrieval-only DP-style implementations (§VI-B), and PAD’s email-vs-name split (§VI-C).

A. Canary validation: the email channel of LPRAG holds on out-of-vocabulary strings

The cleanest evidence is an exact-match out-of-vocabulary (OOV) email canary: it is scored on the generated text with no heuristic classifier in the loop, and its domain is outside any defense’s substitution dictionary, so a defense cannot “win” it by reshaping a placeholder vocabulary.

Protocol. Following Carlini et al. [10], we inject OOV email canaries of the form operator_N@acmetest-internal.canary (50 canaries, one per document) into a 50-document synthetic KB and attack with PS at three seeds, using a 50-query *targeted stress-test* pool (the first 10 match the shared extraction pool; the other 40 are email/identifier-targeted prompts that do not leak the canary prefix or domain). This stress-tests exploitability, not a deployment rate: the 35.3% NO-DEFENSE recovery is what a targeted adversary extracts. Scoring is exact string match.

Result. Across 3 seeds with 50 canaries each ($n = 150$), NO-DEFENSE recovers 53/150 (35.3%) and LPRAG recovers 0/150. A Fisher one-sided test treating the canary opportunities as independent gives $p < 10^{-14}$; because they are grouped by seed, the load-bearing evidence is the consistent per-seed pattern (Table III), not the asymptotic p -value. Since each canary’s domain is outside LPRAG’s placeholder dictionary, LPRAG’s reduction on the EMAIL_REAL sub-class of NEL_{strict} is not scorer-vocabulary bias but the substitution path applying to the tested OOV email-shaped strings.

Aggregate NEL_{strict} split. On the aggregate, LPRAG cuts the EMAIL_REAL mean from 2.25 to 0.10 per run (95.6%, canary-validated above). Its PERSON_NAME mean drops from 1.75 to 0.00 (100%), but this is definitional, not validated: the classifier’s PLACEHOLDER_NAME set *is* LPRAG’s NAME_VOCABULARY, so every name LPRAG writes is excluded from PERSON_NAME by construction. We do *not* claim coverage of person-name leakage under LPRAG; an analogous OOV person-name canary is future work.

TABLE II

AUDIT DASHBOARD. EMAIL/NAME COLUMNS ARE THE MAIN NEL_{strict} SPLIT (PER-RUN MEANS FOR NO-DEFENSE; SIGNED REDUCTIONS OTHERWISE, POSITIVE = LESS LEAKAGE); MI AUC IS SYNTHETIC-CORP ($\times 100$, 50 = CHANCE).

Defense	Hook active	Email NEL (heur.)	Person-name NEL (heur.)	MI AUC (50=chance)
NO-DEFENSE	—	2.25 per run (baseline)	1.75 per run (baseline)	70.5
DP-R	retrieval DP only	+8.1% (Ex)	−9.5% (Ex)	59.3
CA-DP	retrieval DP only	+5.9% (Ex)	−17.1% (Ex)	41.5 [†]
PRIVATE-RAG	retrieval DP only	+11.9% (Ex)	−24.8% (Ex)	49.7 [†]
PAD	regex (gen, emails)	+100.0% on Syn-Email patt.	−42.9% (Ex)	30.0 [†]
LPRAG	entity sub. (both)	+95.6% canary-val.	n/a (SE)	8.2 [†]

[†] values < 50 are score reversals (members ranked below non-members), not ranking-able privacy wins. *Ex* = exploratory (heuristic scorer, not independently validated); *SE* = scorer-entangled with LPRAG’s vocabulary; *canary-val.* = validated by the OOV canary (Table III). Hook source in Table I.

TABLE III

OOV CANARY EXACT-MATCH RECOVERY (3 SEEDS, 50 CANARIES/SEED; TARGETED STRESS-TEST POOL, NOT A DEPLOYMENT RATE).

Defense	seed 101	seed 102	seed 103	Mean
NO-DEFENSE	21/50	16/50	16/50	17.7/50 (35.3%)
LPRAG	0/50	0/50	0/50	0.0/50 (0.0%)

B. Channel split: retrieval-only DP-style implementations lower MI AUC but not NEL_{strict}

Our three DP-style implementations (DP-R, CA-DP, PRIVATE-RAG) ship with `TODO-stubbed` `apply_defense_generation` hooks and so apply no explicit generation-stage transformation (Table I). The active-path map predicts, and we observe, a clean separation between the retrieval-sensitive black-box response score (MI) and the named-entity count on the same generated text (NEL_{strict}): only the MI heuristic moves appreciably under these retrieval-only perturbations.

NEL_{strict} does not move appreciably. Averaging over attacks, corpora, modes, and (for DP) ε , NO-DEFENSE emits 3.93 NEL_{strict} items/run (95% within-instantiation interval [2.50, 5.37]). The three DP implementations track this baseline within $\pm 7\%$ (DP-R −1.3%, CA-DP and PRIVATE-RAG −6.1%; negative = slightly more leakage), every interval overlapping NO-DEFENSE. We read this descriptively, not as a significance test.

MI AUC moves. On Synthetic-Corp, NO-DEFENSE MI AUC is 70.5 [68.8, 71.7]; the DP implementations move it to 41.5–59.3, including reversals below 50, consistent with DP noise shrinking $|AUC - 50|$. This is not in tension with the NEL_{strict} null: MI’s black-box response score is retrieval-sensitive (it shifts when the retrieval hook perturbs which documents surface), whereas NEL_{strict} counts named entities in that same text, which the stubs do not transform. Because MI is black-box its AUC can also move under output-surface nuisance, so we treat it as channel-location evidence (§VII), not a calibrated privacy estimate. (On PubMedQA, MI is at the 100 ceiling under NO-DEFENSE and ≥ 97 under DP—an artifact of an index-based oracle over a known 50-abstract KB, not a privacy finding.)

C. PAD blocks emails on Synthetic-Email, not person-name leakage

On Synthetic-Email, NO-DEFENSE emits 5.30 `EMAIL_REAL` and 4.00 `PERSON_NAME` items/run. PAD drives `EMAIL_REAL` to 0.00 but its `PERSON_NAME` count sits at 6.15 (+2.15 vs NO-DEFENSE), so aggregate NEL_{strict} only drops 9.30→6.15: the regex masker blocks the email family it targets but is not a general person-entity defense. We flag the +2.15 name delta as descriptive (our precision spot-check is only 20/20 on a 10-per-class sample, so we do not claim it is mechanistic). A practitioner reading only the aggregate would miss this two-sided pattern. More broadly, the audit makes two metric pathologies legible: **scorer-vocabulary entanglement** (a classifier excluding a defense’s substitution dictionary reports near-perfect protection by construction—hence the `PERSON_NAME` caveat above) and **ambiguous-class inflation** (our scorer routes $\sim 48\%$ of items into ambiguous org/person classes, so reporting NEL_{loose} rather than the strict pair would shift apparent baselines by tens of percent without changing behavior). We therefore treat NEL_{strict} as a precision-oriented lower bound, not a leakage estimate.

VII. SCOPE AND THREATS TO VALIDITY

The audit methodology is general; the numeric findings are case-study evidence on one stack, not a universal ranking of RAG privacy defenses.

Single seed, one stack, synthetic corpora. Each of the 432 raw cells is one run, so every bootstrap interval is within-instantiation only: it captures variance across pooled runs but not over alternative synthetic-corpus realizations or attack-query samples, and is not a population-level interval (the canary sub-experiment of §VI-A is the only one with three independent seeds). The stack is fixed (one LM, embedder, top- k); a larger model might respond differently to DP-retrieval noise. The five extraction attacks are bounded fixed-query baselines; stronger adaptive attackers would plausibly raise NEL_{strict} . Two of three corpora are synthetic, and the “Enron”-labeled runs are *synthetic* emails from a generator that hard-codes Enron-era surnames (§IV-B). Cross-stack and real-corpus generalization is out of scope.

Implementations we audited, not defense families. The channel-split findings are measurement reports about our three benchmark implementations of DP-class defenses, not claims about DP-on-RAG theory or upstream source papers: the three DP-class modules return the response unmodified and PAD’s generation path fires only on a regex match (Table I). A fully-wired DP-RAG baseline requires completing those TODOs, which we mark as follow-on work. The active-path methodology does not depend on this gap—the same protocol would flag any implementation with an inactive hook on a measured channel.

NEL_{strict} is precision-only; MI is not identified. Our scorer audit is a spot-check (20/20 on a 10-per-class positive sample), not a stratified precision estimate, and we did not audit recall, so NEL_{strict} is a lower bound under a stronger attacker; a larger stratified audit and the person-name OOV canary are follow-on work. The MI score correlates with, but is not unique to, membership—defenses that shorten or mask output could lower MI AUC via surface-corruption nuisance—so we phrase the channel split narrowly as “reduced success on this MI protocol” and read MI as channel-location evidence only.

VIII. CONCLUSION

We presented an active-path audit for RAG privacy defenses—hook inventory, metric-to-channel map, canary validation—and applied it to one fixed open-source RAG stack with six defense implementations on a 432-cell grid. Three takeaways:

- **The audit catches a silent-stub failure mode.** Three of six *audited benchmark implementations* modify only retrieval; a black-box benchmark would report them as “MI-reducing defenses” (70.5 → 41.5–59.3) without registering that NEL_{strict} on generated text does not move. The failure mode is benchmark-wrapper active-path drift, not a property of DP defenses as such.
- **Heuristic scorers need canary triangulation.** LPRAG’s email-channel reduction is validated by an OOV canary (53/150 vs. 0/150, $p < 10^{-14}$), but its person-name reduction is scorer-entangled and reported as exploratory, not certified.
- **Regex masking is channel-specific.** PAD blocks email-format strings but not person-name leakage; the audit makes the specificity legible.

Before asking whether a RAG privacy defense works, ask where it acts. The NEL classifier, analysis scripts, canary generator, and 432 cleaned runs will be released at de-anonymization.

REFERENCES

- [1] M. Abdin, J. Aneja, H. Awadalla, A. Awadallah, A. A. Awan *et al.*, “Phi-3 technical report: A highly capable language model locally on your phone,” *arXiv preprint arXiv:2404.14219*, 2024. [Online]. Available: <https://arxiv.org/abs/2404.14219>
- [2] J. Johnson, M. Douze, and H. Jégou, “Billion-scale similarity search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.
- [3] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence embeddings using Siamese BERT-networks,” in *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP)*. Association for Computational Linguistics, 2019, pp. 3982–3992. [Online]. Available: <https://aclanthology.org/D19-1410/>
- [4] C. Jiang, X. Pan, G. Hong, C. Bao, Y. Chen, and M. Yang, “Feedback-guided extraction of knowledge base from retrieval-augmented LLM applications,” *arXiv preprint arXiv:2411.14110*, 2024, introduces the “RAG-Thief” agent-based extraction attack; v1 title and later revisions differ. [Online]. Available: <https://arxiv.org/abs/2411.14110>
- [5] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, “Membership inference attacks against machine learning models,” in *2017 IEEE Symposium on Security and Privacy (S&P)*. IEEE Computer Society, 2017, pp. 3–18.
- [6] L. He, P. Tang, Y. Zhang, P. Zhou, and S. Su, “Mitigating privacy risks in retrieval-augmented generation via locally private entity perturbation,” *Information Processing & Management*, vol. 62, no. 4, p. 104150, 2025.
- [7] S. Zeng, J. Zhang, P. He, Y. Liu, Y. Xing, H. Xu, J. Ren, Y. Chang, S. Wang, D. Yin, and J. Tang, “The good and the bad: Exploring privacy issues in retrieval-augmented generation (RAG),” in *Findings of the Association for Computational Linguistics: ACL 2024*. Association for Computational Linguistics, 2024, pp. 4505–4524. [Online]. Available: <https://aclanthology.org/2024.findings-acl.267/>
- [8] N. Carlini, F. Tramèr, E. Wallace, M. Jagielski, A. Herbert-Voss, K. Lee, A. Roberts, T. Brown, D. Song, Ú. Erlingsson, A. Oprea, and C. Raffel, “Extracting training data from large language models,” in *30th USENIX Security Symposium (USENIX Security 21)*. USENIX Association, 2021, pp. 2633–2650. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity21/presentation/carlini-extracting>
- [9] N. Carlini, S. Chien, M. Nasr, S. Song, A. Terzis, and F. Tramèr, “Membership inference attacks from first principles,” in *2022 IEEE Symposium on Security and Privacy (S&P)*. IEEE, 2022, pp. 1897–1914.
- [10] N. Carlini, C. Liu, Ú. Erlingsson, J. Kos, and D. Song, “The secret sharer: Evaluating and testing unintended memorization in neural networks,” in *28th USENIX Security Symposium (USENIX Security 19)*. USENIX Association, 2019, pp. 267–284. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity19/presentation/carlini>
- [11] T. Koga, R. Wu, Z. Zhang, and K. Chaudhuri, “Privacy-preserving retrieval-augmented generation with differential privacy,” *arXiv preprint arXiv:2412.04697*, 2024. [Online]. Available: <https://arxiv.org/abs/2412.04697>
- [12] I. D. Raji, A. Smart, R. N. White, M. Mitchell, T. Gebru, B. Hutchinson, J. Smith-Loud, D. Theron, and P. Barnes, “Closing the AI accountability gap: Defining an end-to-end framework for internal algorithmic auditing,” in *Proceedings of the 2020 Conference on Fairness, Accountability, and Transparency (FAT*)*, 2020, pp. 33–44.
- [13] Y. Li, Z. Fan, and Z. Zhuang, “Auditing reasoning-trace memorization claims after unlearning with head-conditioned canaries,” *arXiv preprint arXiv:2605.18891*, 2026. [Online]. Available: <https://arxiv.org/abs/2605.18891>
- [14] Y. Li, Z. Fan, and Z. Zhuang, “SafetyRepro: Configuration-conditional rank instability on alignment benchmarks,” *arXiv preprint arXiv:2605.25492*, 2026. [Online]. Available: <https://arxiv.org/abs/2605.25492>
- [15] Z. Zhuang, Y. Li, and Z. Fan, “Pre-registering the detectable effect: A paired-MDE budget for 4-bit quantization benchmarks, with a pilot audit,” *arXiv preprint arXiv:2605.28873*, 2026. [Online]. Available: <https://arxiv.org/abs/2605.28873>
- [16] Y. Wang, X. Sun, Y. Li, Z. Fan, and Z. Zhuang, “Auditing and fixing economic validity in tabular foundation models for discrete choice,” *arXiv preprint arXiv:2605.26559*, 2026. [Online]. Available: <https://arxiv.org/abs/2605.26559>
- [17] Q. Jin, B. Dhingra, Z. Liu, W. W. Cohen, and X. Lu, “PubMedQA: A dataset for biomedical research question answering,” in *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP)*. Association for Computational Linguistics, 2019, pp. 2567–2577. [Online]. Available: <https://aclanthology.org/D19-1259/>